



ZAP by
Checkmarx

ZAP by Checkmarx Scanning Report

Site: <http://localhost:3000>

Generated on Wed, 16 Sept 2026 02:19:42

ZAP Version: 2.17.0

ZAP by [Checkmarx](#)

Summary of Alerts

Risk Level	Number of Alerts
High	1
Medium	4
Low	3
Informational	1

Insights

Level	Reason	Site	Description	Statistic
Low	Warning		ZAP warnings logged - see the zap. log file for details	17
Info	Informational	http://localhost:3000	Percentage of responses with status code 1xx	1 %
Info	Informational	http://localhost:3000	Percentage of responses with status code 2xx	44 %
Info	Informational	http://localhost:3000	Percentage of responses with status code 3xx	8 %
Info	Exceeded Low	http://localhost:3000	Percentage of responses with status code 4xx	44 %
Info	Informational		Percentage of	2 %

		http://localhost:3000	responses with status code 5xx	
Info	Informational	http://localhost:3000	Percentage of endpoints with content type application/javascript	4 %
Info	Informational	http://localhost:3000	Percentage of endpoints with content type application/json	4 %
Info	Informational	http://localhost:3000	Percentage of endpoints with content type application/octet-stream	2 %
Info	Informational	http://localhost:3000	Percentage of endpoints with content type image/jpeg	6 %
Info	Informational	http://localhost:3000	Percentage of endpoints with content type image/png	3 %
Info	Informational	http://localhost:3000	Percentage of endpoints with content type image/x-icon	4 %
Info	Informational	http://localhost:3000	Percentage of endpoints with content type text/css	4 %
Info	Informational	http://localhost:3000	Percentage of endpoints with content type text/html	72 %

Info	Informational	http://localhost:3000	Percentage of endpoints with content type text/markdown	1 %
Info	Informational	http://localhost:3000	Percentage of endpoints with content type text/plain	1 %
Info	Informational	http://localhost:3000	Percentage of endpoints with method GET	99 %
Info	Informational	http://localhost:3000	Count of total endpoints	174
Info	Exceeded Low	http://localhost:3000	Percentage of slow responses	7 %

Alerts

Name	Risk Level	Number of Instances
SQL Injection	High	1
Content Security Policy (CSP) Header Not Set	Medium	Systemic
Cross-Domain Misconfiguration	Medium	Systemic
Missing Anti-clickjacking Header	Medium	1
Session ID in URL Rewrite	Medium	Systemic
Private IP Disclosure	Low	1
Timestamp Disclosure - Unix	Low	Systemic
X-Content-Type-Options Header Missing	Low	3
Modern Web Application	Informational	Systemic

Alert Detail

High	SQL Injection
Description	SQL injection may be possible.
URL	http://localhost:3000/rest/products/search?q=%27%28
Node Name	http://localhost:3000/rest/products/search (q)
Method	GET
Attack	'(
Evidence	HTTP/1.1 500 Internal Server Error

Other Info	
Instances	1
Solution	Do not trust client side input, even if there is client side validation in place. In general, type check all data on the server side. If the application uses JDBC, use PreparedStatement or CallableStatement, with parameters passed by '?' If the application uses ASP, use ADO Command Objects with strong type checking and parameterized queries. If database Stored Procedures can be used, use them. Do <i>not</i> concatenate strings into queries in the stored procedure, or use 'exec', 'exec immediate', or equivalent functionality! Do not create dynamic SQL queries using simple string concatenation. Escape all data received from the client. Apply an 'allow list' of allowed characters, or a 'deny list' of disallowed characters in user input. Apply the principle of least privilege by using the least privileged database user possible. In particular, avoid using the 'sa' or 'db-owner' database users. This does not eliminate SQL injection, but minimizes its impact. Grant the minimum database access that is necessary for the application.
Reference	https://cheatsheetseries.owasp.org/cheatsheets/SQL_Injection_Prevention_Cheat_Sheet.html
CWE Id	89
WASC Id	19
Plugin Id	40018

Medium	Content Security Policy (CSP) Header Not Set
Description	Content Security Policy (CSP) is an added layer of security that helps to detect and mitigate certain types of attacks, including Cross Site Scripting (XSS) and data injection attacks. These attacks are used for everything from data theft to site defacement or distribution of malware. CSP provides a set of standard HTTP headers that allow website owners to declare approved sources of content that browsers should be allowed to load on that page — covered types are JavaScript, CSS, HTML frames, fonts, images and embeddable objects such as Java applets, ActiveX, audio and video files.
URL	http://localhost:3000
Node Name	http://localhost:3000
Method	GET
Attack	
Evidence	
Other Info	
URL	http://localhost:3000/
Node Name	http://localhost:3000/
Method	GET

Attack	
Evidence	
Other Info	
URL	http://localhost:3000/ftp/eastere.gg
Node Name	http://localhost:3000/ftp/eastere.gg
Method	GET
Attack	
Evidence	
Other Info	
URL	http://localhost:3000/ftp/encrypt.pyc
Node Name	http://localhost:3000/ftp/encrypt.pyc
Method	GET
Attack	
Evidence	
Other Info	
URL	http://localhost:3000/sitemap.xml
Node Name	http://localhost:3000/sitemap.xml
Method	GET
Attack	
Evidence	
Other Info	
Instances	Systemic
Solution	Ensure that your web server, application server, load balancer, etc. is configured to set the Content-Security-Policy header.
Reference	https://developer.mozilla.org/en-US/docs/Web/HTTP/Guides/CSP https://cheatsheetseries.owasp.org/cheatsheets/Content_Security_Policy_Cheat_Sheet.html https://www.w3.org/TR/CSP/ https://w3c.github.io/webappsec-csp/ https://web.dev/articles/csp https://caniuse.com/#feat=contentsecuritypolicy https://content-security-policy.com/
CWE Id	693
WASC Id	15
Plugin Id	10038

Medium	Cross-Domain Misconfiguration
Description	Web browser data loading may be possible, due to a Cross Origin Resource Sharing (CORS) misconfiguration on the web server.
URL	http://localhost:3000/assets/public/favicon_js.ico
Node Name	http://localhost:3000/assets/public/favicon_js.ico

Method	GET
Attack	
Evidence	Access-Control-Allow-Origin: *
Other Info	The CORS misconfiguration on the web server permits cross-domain read requests from arbitrary third party domains, using unauthenticated APIs on this domain. Web browser implementations do not permit arbitrary third parties to read the response from authenticated APIs, however. This reduces the risk somewhat. This misconfiguration could be used by an attacker to access data that is available in an unauthenticated manner, but which uses some other form of security, such as IP address white-listing.
URL	http://localhost:3000/polyfills.js
Node Name	http://localhost:3000/polyfills.js
Method	GET
Attack	
Evidence	Access-Control-Allow-Origin: *
Other Info	The CORS misconfiguration on the web server permits cross-domain read requests from arbitrary third party domains, using unauthenticated APIs on this domain. Web browser implementations do not permit arbitrary third parties to read the response from authenticated APIs, however. This reduces the risk somewhat. This misconfiguration could be used by an attacker to access data that is available in an unauthenticated manner, but which uses some other form of security, such as IP address white-listing.
URL	http://localhost:3000/robots.txt
Node Name	http://localhost:3000/robots.txt
Method	GET
Attack	
Evidence	Access-Control-Allow-Origin: *
Other Info	The CORS misconfiguration on the web server permits cross-domain read requests from arbitrary third party domains, using unauthenticated APIs on this domain. Web browser implementations do not permit arbitrary third parties to read the response from authenticated APIs, however. This reduces the risk somewhat. This misconfiguration could be used by an attacker to access data that is available in an unauthenticated manner, but which uses some other form of security, such as IP address white-listing.
URL	http://localhost:3000/scripts.js
Node Name	http://localhost:3000/scripts.js
Method	GET
Attack	
Evidence	Access-Control-Allow-Origin: *
Other Info	The CORS misconfiguration on the web server permits cross-domain read requests from arbitrary third party domains, using unauthenticated APIs on this domain. Web browser implementations do not permit arbitrary third parties to read the response from authenticated APIs, however. This reduces the risk somewhat. This misconfiguration could be used by an attacker to access data that is available in an unauthenticated manner, but which uses some other form of security, such as IP address white-listing.
URL	http://localhost:3000/styles.css
Node Name	http://localhost:3000/styles.css
Method	GET
Attack	
Evidence	Access-Control-Allow-Origin: *

Other Info	The CORS misconfiguration on the web server permits cross-domain read requests from arbitrary third party domains, using unauthenticated APIs on this domain. Web browser implementations do not permit arbitrary third parties to read the response from authenticated APIs, however. This reduces the risk somewhat. This misconfiguration could be used by an attacker to access data that is available in an unauthenticated manner, but which uses some other form of security, such as IP address white-listing.
Instances	Systemic
Solution	Ensure that sensitive data is not available in an unauthenticated manner (using IP address white-listing, for instance). Configure the "Access-Control-Allow-Origin" HTTP header to a more restrictive set of domains, or remove all CORS headers entirely, to allow the web browser to enforce the Same Origin Policy (SOP) in a more restrictive manner.
Reference	https://vuln.catfortify.com/en/detail?category=HTML5&subcategory=Overly%20Permissive%20CORS%20Policy
CWE Id	264
WASC Id	14
Plugin Id	10098

Medium	Missing Anti-clickjacking Header
Description	The response does not protect against 'ClickJacking' attacks. It should include either Content-Security-Policy with 'frame-ancestors' directive or X-Frame-Options.
URL	http://localhost:3000/socket.io/?EIO=4&transport=polling&t=Q2csTZC&sid=n87vatf5EfUi5QgoAAAC
Node Name	http://localhost:3000/socket.io/ (EIO,sid,t,transport)(40)
Method	POST
Attack	
Evidence	
Other Info	
Instances	1
Solution	Modern Web browsers support the Content-Security-Policy and X-Frame-Options HTTP headers. Ensure one of them is set on all web pages returned by your site/app. If you expect the page to be framed only by pages on your server (e.g. it's part of a FRAMESET) then you'll want to use SAMEORIGIN, otherwise if you never expect the page to be framed, you should use DENY. Alternatively consider implementing Content Security Policy's "frame-ancestors" directive.
Reference	https://developer.mozilla.org/en-US/docs/Web/HTTP/Reference/Headers/X-Frame-Options
CWE Id	1021
WASC Id	15
Plugin Id	10020

Medium	Session ID in URL Rewrite
Description	URL rewrite is used to track user session ID. The session ID may be disclosed via cross-site referer header. In addition, the session ID might be stored in browser history or server logs.
URL	http://localhost:3000/socket.io/?EIO=4&transport=polling&t=Q2csUEd&sid=VkOSKIoEJpEi_EdGAAAE
Node Name	http://localhost:3000/socket.io/ (EIO,sid,t,transport)
Method	GET

Attack	
Evidence	VkOSKIoEJpEi_EdGAAAE
Other Info	
URL	http://localhost:3000/socket.io/?EIO=4&transport=polling&t=Q2csTZG&sid=n87vatf5EfUi5QgoAAAC
Node Name	http://localhost:3000/socket.io/ (EIO,sid,t,transport)
Method	GET
Attack	
Evidence	n87vatf5EfUi5QgoAAAC
Other Info	
URL	http://localhost:3000/socket.io/?EIO=4&transport=websocket&sid=n87vatf5EfUi5QgoAAAC
Node Name	http://localhost:3000/socket.io/ (EIO,sid,transport)
Method	GET
Attack	
Evidence	n87vatf5EfUi5QgoAAAC
Other Info	
URL	http://localhost:3000/socket.io/?EIO=4&transport=polling&t=Q2csUEX&sid=VkOSKIoEJpEi_EdGAAAE
Node Name	http://localhost:3000/socket.io/ (EIO,sid,t,transport)(40)
Method	POST
Attack	
Evidence	VkOSKIoEJpEi_EdGAAAE
Other Info	
URL	http://localhost:3000/socket.io/?EIO=4&transport=polling&t=Q2csTZC&sid=n87vatf5EfUi5QgoAAAC
Node Name	http://localhost:3000/socket.io/ (EIO,sid,t,transport)(40)
Method	POST
Attack	
Evidence	n87vatf5EfUi5QgoAAAC
Other Info	
Instances	Systemic
Solution	For secure content, put session ID in a cookie. To be even more secure consider using a combination of cookie and URL rewrite.
Reference	https://seclists.org/webappsec/2002/q4/111
CWE Id	598
WASC Id	13
Plugin Id	3



Low	Private IP Disclosure
Description	A private IP (such as 10.x.x.x, 172.x.x.x, 192.168.x.x) or an Amazon EC2 private hostname (for example, ip-10-0-56-78) has been found in the HTTP response body. This information might be helpful for further attacks targeting internal systems.
URL	http://localhost:3000/rest/admin/application-configuration
Node Name	http://localhost:3000/rest/admin/application-configuration
Method	GET
Attack	
Evidence	192.168.99.100:3000
Other Info	192.168.99.100:3000 192.168.99.100:4200
Instances	1
Solution	Remove the private IP address from the HTTP response body. For comments, use JSP/ASP/PHP comment instead of HTML/JavaScript comment which can be seen by client browsers.
Reference	https://datatracker.ietf.org/doc/html/rfc1918
CWE Id	497
WASC Id	13
Plugin Id	2

Low	Timestamp Disclosure - Unix
Description	A timestamp was disclosed by the application/web server. - Unix
URL	http://localhost:3000
Node Name	http://localhost:3000
Method	GET
Attack	
Evidence	1666666667
Other Info	1666666667, which evaluates to: 2022-10-25 07:57:47.
URL	http://localhost:3000
Node Name	http://localhost:3000
Method	GET
Attack	
Evidence	1839622642
Other Info	1839622642, which evaluates to: 2028-04-18 03:17:22.
URL	http://localhost:3000/sitemap.xml
Node Name	http://localhost:3000/sitemap.xml
Method	GET
Attack	
Evidence	1666666667
Other Info	1666666667, which evaluates to: 2022-10-25 07:57:47.

URL	http://localhost:3000/sitemap.xml
Node Name	http://localhost:3000/sitemap.xml
Method	GET
Attack	
Evidence	1839622642
Other Info	1839622642, which evaluates to: 2028-04-18 03:17:22.
URL	http://localhost:3000/styles.css
Node Name	http://localhost:3000/styles.css
Method	GET
Attack	
Evidence	1528301887
Other Info	1528301887, which evaluates to: 2018-06-06 21:18:07.
Instances	Systemic
Solution	Manually confirm that the timestamp data is not sensitive, and that the data cannot be aggregated to disclose exploitable patterns.
Reference	https://cwe.mitre.org/data/definitions/200.html
CWE Id	497
WASC Id	13
Plugin Id	10096

Low	X-Content-Type-Options Header Missing
Description	The Anti-MIME-Sniffing header X-Content-Type-Options was not set to 'nosniff'. This allows older versions of Internet Explorer and Chrome to perform MIME-sniffing on the response body, potentially causing the response body to be interpreted and displayed as a content type other than the declared content type. Current (early 2014) and legacy versions of Firefox will use the declared content type (if one is set), rather than performing MIME-sniffing.
URL	http://localhost:3000/socket.io/?EIO=4&transport=polling&t=Q2csTZG&sid=n87vatf5EfUi5QgoAAAC
Node Name	http://localhost:3000/socket.io/ (EIO,sid,t,transport)
Method	GET
Attack	
Evidence	
Other Info	This issue still applies to error type pages (401, 403, 500, etc.) as those pages are often still affected by injection issues, in which case there is still concern for browsers sniffing pages away from their actual content type. At "High" threshold this scan rule will not alert on client or server error responses.
URL	http://localhost:3000/socket.io/?EIO=4&transport=polling&t=Q2csTWX
Node Name	http://localhost:3000/socket.io/ (EIO,t,transport)
Method	GET
Attack	
Evidence	

Other Info	This issue still applies to error type pages (401, 403, 500, etc.) as those pages are often still affected by injection issues, in which case there is still concern for browsers sniffing pages away from their actual content type. At "High" threshold this scan rule will not alert on client or server error responses.
URL	http://localhost:3000/socket.io/?EIO=4&transport=polling&t=Q2csTZC&sid=n87vatf5EfUi5QgoAAAC
Node Name	http://localhost:3000/socket.io/ (EIO,sid,t,transport)(40)
Method	POST
Attack	
Evidence	
Other Info	This issue still applies to error type pages (401, 403, 500, etc.) as those pages are often still affected by injection issues, in which case there is still concern for browsers sniffing pages away from their actual content type. At "High" threshold this scan rule will not alert on client or server error responses.
Instances	3
Solution	Ensure that the application/web server sets the Content-Type header appropriately, and that it sets the X-Content-Type-Options header to 'nosniff' for all web pages. If possible, ensure that the end user uses a standards-compliant and modern web browser that does not perform MIME-sniffing at all, or that can be directed by the web application /web server to not perform MIME-sniffing.
Reference	https://learn.microsoft.com/en-us/previous-versions/windows/internet-explorer/ie-developer/compatibility/gg622941(v=vs.85) https://owasp.org/www-community/Security-Headers
CWE Id	693
WASC Id	15
Plugin Id	10021

Informational	Modern Web Application
Description	The application appears to be a modern web application. If you need to explore it automatically then the Client Spider may well be more effective than the standard one.
URL	http://localhost:3000
Node Name	http://localhost:3000
Method	GET
Attack	
Evidence	<pre><script> window.addEventListener("load", function(){ window.cookieconsent.initialise({ "palette": { "popup": { "background": "var(--theme-primary)", "text": "var(--theme-text)" }, "button": { "background": "var(--theme-accent)", "text": "var(--theme-text)" } }, "theme": "classic", "position": "bottom-right", "content": { "message": "This website uses fruit cookies to ensure you get the juiciest tracking experience.", "dismiss": "Me want it!", "link": "But me wait!", "href": "https://www.youtube.com/watch?v=9PnbKL3wuH4" } })); </script></pre>
Other Info	No links have been found while there are scripts, which is an indication that this is a modern web application.
URL	http://localhost:3000/
Node Name	http://localhost:3000/
Method	GET
Attack	
	<pre><script> window.addEventListener("load", function(){ window.cookieconsent.initialise({</pre>

Evidence	"palette": { "popup": { "background": "var(--theme-primary)", "text": "var(--theme-text)" }, "button": { "background": "var(--theme-accent)", "text": "var(--theme-text)" } }, "theme": "classic", "position": "bottom-right", "content": { "message": "This website uses fruit cookies to ensure you get the juiciest tracking experience.", "dismiss": "Me want it!", "link": "But me wait!", "href": "https://www.youtube.com/watch?v=9PnbKL3wuH4" } } } } </script>
Other Info	No links have been found while there are scripts, which is an indication that this is a modern web application.
URL	http://localhost:3000/juice-shop/build/routes/fileServer.js:68:18
Node Name	http://localhost:3000/juice-shop/build/routes/fileServer.js:68:18
Method	GET
Attack	
Evidence	<script> window.addEventListener("load", function(){ window.cookieconsent.initialise({ "palette": { "popup": { "background": "var(--theme-primary)", "text": "var(--theme-text)" }, "button": { "background": "var(--theme-accent)", "text": "var(--theme-text)" } }, "theme": "classic", "position": "bottom-right", "content": { "message": "This website uses fruit cookies to ensure you get the juiciest tracking experience.", "dismiss": "Me want it!", "link": "But me wait!", "href": "https://www.youtube.com/watch?v=9PnbKL3wuH4" } } } } </script>
Other Info	No links have been found while there are scripts, which is an indication that this is a modern web application.
URL	http://localhost:3000/juice-shop/node_modules/express/lib/router/layer.js:95:5
Node Name	http://localhost:3000/juice-shop/node_modules/express/lib/router/layer.js:95:5
Method	GET
Attack	
Evidence	<script> window.addEventListener("load", function(){ window.cookieconsent.initialise({ "palette": { "popup": { "background": "var(--theme-primary)", "text": "var(--theme-text)" }, "button": { "background": "var(--theme-accent)", "text": "var(--theme-text)" } }, "theme": "classic", "position": "bottom-right", "content": { "message": "This website uses fruit cookies to ensure you get the juiciest tracking experience.", "dismiss": "Me want it!", "link": "But me wait!", "href": "https://www.youtube.com/watch?v=9PnbKL3wuH4" } } } } </script>
Other Info	No links have been found while there are scripts, which is an indication that this is a modern web application.
URL	http://localhost:3000/sitemap.xml
Node Name	http://localhost:3000/sitemap.xml
Method	GET
Attack	
Evidence	<script> window.addEventListener("load", function(){ window.cookieconsent.initialise({ "palette": { "popup": { "background": "var(--theme-primary)", "text": "var(--theme-text)" }, "button": { "background": "var(--theme-accent)", "text": "var(--theme-text)" } }, "theme": "classic", "position": "bottom-right", "content": { "message": "This website uses fruit cookies to ensure you get the juiciest tracking experience.", "dismiss": "Me want it!", "link": "But me wait!", "href": "https://www.youtube.com/watch?v=9PnbKL3wuH4" } } } } </script>
Other Info	No links have been found while there are scripts, which is an indication that this is a modern web application.
Instances	Systemic
Solution	This is an informational alert and so no changes are required.
Reference	
CWE Id	
WASC Id	
Plugin Id	10109

